VULNERABILITY ASSESSMENT & PENETRATION TEST REPORT

Assessment A-14ca676a

Generated by ARGUS (AI-assisted, evidence-grounded) · assessment A-14ca676a

Authorized scope	10.77.0.0/24
Exclusions	10.77.0.1, 10.77.0.2, 10.77.0.3
Authorized by	Team ARGUS (own isolated lab)
Assessment window	2026-11-07T07:14:01+00:00 to 2026-11-07T07:24:15+00:00 (UTC)
Report status	review; audit chain verified intact

Important. This report was produced by an automated assistant from real tool output. Findings marked *suspected* or *observed* have not been manually verified. Use of the standards named here (NIST SP 800-115, OWASP Top 10, CVE, CVSS, CWE, MITRE ATT&CK, NIST CSF 2.0) is indicative and does not establish formal compliance.

1. Executive Summary

ARGUS assessed 1 authorized target(s) (10.77.0.0/24) and identified **35** distinct finding(s) across 2 host(s), plus 19 informational observation(s) (Appendix E). 2 additional tool alert(s) were investigated and **refuted as false positives**; they are listed in Appendix B and excluded from the risk ranking. 9 finding(s) were independently validated, and 6 were reported independently by more than one tool.

Highest-priority issues (ranked by a transparent score, see section 3): **F-055** Cross-site scripting (reflected) on 10.77.0.10:80 (priority 7.3, observed) [EV-0021]; **F-030** SQL Injection on 10.77.0.10:80 (priority 6.8, observed) [EV-0003] [EV-0018]; **F-002** Content Security Policy (CSP) Header Not Set on 10.77.0.10:80 (priority 6.0, validated) [EV-0003] [EV-0006].

Overall assessment. Significant weaknesses were found that warrant prompt remediation.

Scope and rules of engagement. All testing was restricted to the authorized lab scope above. Active or intrusive actions required recorded human approval (section 6).

2. Assessment Methodology

The assessment followed the planning, discovery, attack (validation) and reporting phases of NIST SP 800-115. The agent selected each next action from its current evidence (Decision Cards, Appendix C) rather than a fixed script. Every action passed a deterministic scope check and was written to a hash-chained audit log.

Assets tested

10.77.0.10:- (n/a), 10.77.0.10:80 (http), 10.77.0.10:80 (www), 10.77.0.11:3000 (http)

Tool execution summary

Job	Tool	Mode	Target	Status	Started	Detail
J-001	nmap	LIVE	10.77.0.0/24	OK	07:14:05	
J-002	nmap	LIVE	10.77.0.10	OK	07:14:23	
J-003	zap	LIVE	http://10.77.0.10	OK	07:14:32	
J-004	zap	LIVE	http://10.77.0.11:3000	OK	07:14:42	
J-005	nmap	LIVE	10.77.0.11	OK	07:15:10	
J-006	nikto	LIVE	http://10.77.0.10	OK	07:15:27	
J-009	nikto	LIVE	http://10.77.0.11:3000	OK	07:15:36	
J-012	argus-http	LIVE	http://10.77.0.10	OK	07:18:16	
J-013	argus-http	LIVE	http://10.77.0.10	OK	07:18:17	
J-014	argus-http	LIVE	http://10.77.0.10/login.php	OK	07:18:17	
J-015	argus-http	LIVE	http://10.77.0.10/sitemap.xml	OK	07:18:18	
J-016	argus-http	LIVE	http://10.77.0.10:80/	OK	07:18:18	
J-017	argus-http	LIVE	http://10.77.0.10/dvwa/css/login.c	OK	07:18:19	
J-018	argus-http	LIVE	http://10.77.0.10/sitemap.xml	OK	07:18:19	
J-019	argus-http	LIVE	http://10.77.0.10/dvwa/css/	OK	07:18:19	
J-020	argus-http	LIVE	http://10.77.0.11:3000	OK	07:18:19	
J-021	argus-http	LIVE	http://10.77.0.11:3000/	OK	07:18:20	
J-022	zap	LIVE	http://10.77.0.10	OK	07:18:32	
J-023	metasploit	LIVE	10.77.0.10	OK	07:21:57	
J-024	argus-http	LIVE	http://10.77.0.10/sitemap.xml	OK	07:23:07	

Job	Tool	Mode	Target	Status	Started	Detail
-	nessus	IMPORT	imported file SAMPLE-sample_nessus	OK	07:22:43	file imported, not executed
-	burp	IMPORT	imported file SAMPLE-sample_burp_d	OK	07:22:46	file imported, not executed
-	openvas	IMPORT	imported file SAMPLE-sample_openva	OK	07:22:49	file imported, not executed
-	nessus	IMPORT	imported file oos.nessus	OK	07:22:55	file imported, not executed
-	nessus	IMPORT	imported file bad.nessus	OK	07:23:00	file imported, not executed

Integration status (truthful)

Tool	Status	Runtime now	Limitations
nmap	LIVE	ready	Requires the argus-tools container. No vulners script: CVE hints come only from a small reference table.
nessus	IMPORT-ONLY	ready	Commercial product; live API integration is not implemented or claimed. Informational plugins are treated as context.
openvas	IMPORT-ONLY	ready	Live GMP integration is Planned (Greenbone community feed sync is heavy); import is supported.
nikto	LIVE	ready	Nikto reports no CVSS and no severity; ARGUS derives a coarse severity from the message and marks it as derived.
zap	LIVE	ready	Needs the argus-zap daemon. ZAP does not provide CVSS scores; none are fabricated.
burp	IMPORT-ONLY	ready	Burp Community has no scanner export/API; Burp Pro REST API integration is Planned, not implemented.
metasploit	LIVE	ready	Requires the metasploit-framework Docker image (large) and an approved action. Exploit modules are NOT supported by design. Not autonomous.

3. Severity Distribution and Prioritized Findings

Severity (as reported)	Count
CRITICAL	0
HIGH	2
MEDIUM	17
LOW	16
INFO	0

How priority is computed: priority = min(10, base × exposure × exploitability × asset criticality × confidence weight). Base is the CVSS score reported by a tool; when no tool supplies CVSS, the midpoint of the tool-reported severity is used and labelled as such. No CVSS value in this report was generated by ARGUS. The KEV check uses a small, partial offline snapshot.

Rank	ID	Finding	Asset	Sev.	Priority	Status	Conf.
1	F-055	Cross-site scripting (reflected)	10.77.0.10:80	HIGH	7.3	observed	50 (medium)
2	F-030	SQL Injection	10.77.0.10:80	HIGH	6.8	observed	40 (medium)
3	F-002	Content Security Policy (CSP) Header Not Set	10.77.0.10:80	MEDIUM	6.0	validated	90 (high)
4	F-012	Directory Browsing	10.77.0.10:80	MEDIUM	5.5	validated	90 (high)
5	F-032	Content Security Policy (CSP) Header Not Set	10.77.0.11:3000	MEDIUM	5.5	validated	90 (high)
6	F-025	Absence of Anti-CSRF Tokens	10.77.0.10:80	MEDIUM	5.2	observed	55 (medium)
7	F-006	Missing Anti-clickjacking Header	10.77.0.10:80	MEDIUM	4.8	validated	90 (high)
8	F-011	Application Error Disclosure	10.77.0.10:80	MEDIUM	4.7	observed	55 (medium)
9	F-014	Absence of Anti-CSRF Tokens	10.77.0.10:80	MEDIUM	4.7	observed	55 (medium)
10	F-015	Absence of Anti-CSRF Tokens	10.77.0.10:80	MEDIUM	4.7	observed	55 (medium)
11	F-017	Absence of Anti-CSRF Tokens	10.77.0.10:80	MEDIUM	4.7	observed	55 (medium)
12	F-018	Sub Resource Integrity Attribute Missing	10.77.0.10:80	MEDIUM	4.7	observed	55 (medium)
13	F-019	Absence of Anti-CSRF Tokens	10.77.0.10:80	MEDIUM	4.7	observed	55 (medium)
14	F-020	CSP: Failure to Define Directive with No Fallback	10.77.0.10:80	MEDIUM	4.7	observed	55 (medium)

Rank	ID	Finding	Asset	Sev.	Priority	Status	Conf.
15	F-021	CSP: Wildcard Directive	10.77.0.10:80	MEDIUM	4.7	observed	55 (medium)
16	F-022	CSP: style-src unsafe-inline	10.77.0.10:80	MEDIUM	4.7	observed	55 (medium)
17	F-023	Absence of Anti-CSRF Tokens	10.77.0.10:80	MEDIUM	4.7	observed	55 (medium)
18	F-024	Absence of Anti-CSRF Tokens	10.77.0.10:80	MEDIUM	4.7	observed	55 (medium)
19	F-031	Cross-Domain Misconfiguration	10.77.0.11:3000	MEDIUM	4.7	observed	55 (medium)
20	F-003	Cookie No HttpOnly Flag	10.77.0.10:80	LOW	3.0	validated	90 (high)
21	F-054	Web Server Transmits Cleartext Credentials	10.77.0.10:80	LOW	2.6	observed	35 (low)
22	F-005	Cookie without SameSite Attribute	10.77.0.10:80	LOW	2.5	validated	90 (high)
23	F-007	Server Leaks Version Information via "Server" HTTP Response Header Fie	10.77.0.10:80	LOW	2.5	validated	90 (high)
24	F-008	X-Content-Type-Options Header Missing	10.77.0.10:80	LOW	2.5	validated	90 (high)
25	F-034	Apache/2.4.25 appears to be outdated (current is at least 2.4.68).	10.77.0.10:80	LOW	2.5	validated	90 (high)
26	F-056	TCP Timestamps Information Disclosure	10.77.0.10:-	LOW	2.2	observed	35 (low)
27	F-004	In Page Banner Information Leak	10.77.0.10:80	LOW	2.1	observed	55 (medium)
28	F-013	Information Disclosure - Debug Error Messages	10.77.0.10:80	LOW	2.1	observed	55 (medium)
29	F-016	Cross-Domain JavaScript Source File Inclusion	10.77.0.10:80	LOW	2.1	observed	55 (medium)
30	F-026	Timestamp Disclosure - Unix	10.77.0.10:80	LOW	2.1	observed	55 (medium)
31	F-028	Private IP Disclosure	10.77.0.10:80	LOW	2.1	observed	55 (medium)
32	F-035	Suggested security header missing: permissions-policy.	10.77.0.10:80	LOW	2.1	observed	40 (medium)
33	F-037	Suggested security header missing: referrer-policy.	10.77.0.10:80	LOW	2.1	observed	40 (medium)

Rank	ID	Finding	Asset	Sev.	Priority	Status	Conf.
34	F-047	Suggested security header missing: permissions-policy.	10.77.0.11:3000	LOW	2.1	observed	40 (medium)
35	F-048	Suggested security header missing: referrer-policy.	10.77.0.11:3000	LOW	2.1	observed	40 (medium)

4. Detailed Vulnerability Findings

F-055 — Cross-site scripting (reflected)

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/vulnerabilities/xss_r/ Parameter: name parameter
Severity / CVSS	**HIGH** (reported by burp) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-79 / A03:2021 Injection
MITRE ATT&CK (indicative)	T1059.007
Validation status	**OBSERVED** · confidence 50/100 (medium)
Priority	7.3 (rank 1)

OBSERVED (tool evidence): Reflected cross-site scripting vulnerabilities arise when data is copied from a request and echoed into the application's immediate response in an unsafe way.
Reported by: burp (IMPORT) [EV-0021] rule burp:2097920

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | -5 only from an imported file (not re-executed by ARGUS) | burp-confidence:Certain
Risk factors: base 8.0 (no CVSS available; midpoint of 'high' severity (burp)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-030 — SQL Injection

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/setup.php Parameter: create_db
Severity / CVSS	**HIGH** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-89 / A03:2021 Injection
MITRE ATT&CK (indicative)	T1190
Validation status	**OBSERVED** · confidence 40/100 (medium)
Priority	6.8 (rank 2)

OBSERVED (tool evidence): SQL injection may be possible.
Reported by: zap (LIVE) [EV-0003] rule zap:40018, zap (LIVE) [EV-0018] rule zap:40018

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | zap-confidence:Medium
Risk factors: base 8.0 (no CVSS available; midpoint of 'high' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-002 — Content Security Policy (CSP) Header Not Set

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/sitemap.xml, http://10.77.0.10/login.php, http://10.77.0.10/setup.php, http://10.77.0.10/
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-693 / A05:2021 Security Misconfiguration
MITRE ATT&CK (indicative)	n/a
Validation status	**VALIDATED** · confidence 90/100 (high) Validation: confirmed by argus-http-check - No Content-Security-Policy header in the response. [EV-0014]
Priority	6.0 (rank 3)

OBSERVED (tool evidence): Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
Reported by: zap (LIVE) [EV-0003] rule zap:10038, nikto (LIVE) [EV-0006] rule nikto:013587, zap (LIVE) [EV-0018] rule zap:10038

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +25 independently reported by 2 tools (nikto, zap) | zap-confidence:High | retest: still present: No Content-Security-Policy header in the response.
Retest history: 2026-11-07T07:23:07 validated -> validated (confirmed) [EV-0025]
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

F-012 — Directory Browsing

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/dvwa/css/, http://10.77.0.10/dvwa/images/, http://10.77.0.10/dvwa/, http://10.77.0.10/dvwa/images/?C=N;O=D
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-548 / A05:2021 Security Misconfiguration
MITRE ATT&CK (indicative)	n/a
Validation status	**VALIDATED** · confidence 90/100 (high) Validation: confirmed by argus-http-check - The response is an auto-generated directory index ('Index of /'). [EV-0015]
Priority	5.5 (rank 4)

OBSERVED (tool evidence): It is possible to view a listing of the directory contents. Directory listings may reveal hidden scripts, include files, backup source files, etc., which can be accessed to reveal sensitive information. Evidence: <title>Index of /dvwa/includes/DBMS</title>
Reported by: zap (LIVE) [EV-0003] rule zap:10033, nikto (LIVE) [EV-0006] rule nikto:750500, zap (LIVE) [EV-0018] rule zap:10033, nessus (IMPORT) [EV-0020] rule nessus:40984

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +35 independently reported by 3 tools (nessus, nikto, zap) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Medium
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

F-032 — Content Security Policy (CSP) Header Not Set

Affected asset	10.77.0.11:3000 URLs: http://10.77.0.11:3000, http://10.77.0.11:3000/sitemap.xml, http://10.77.0.11:3000/ftp, http://10.77.0.11:3000/ftp/suspicious_errors.yml
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-693 / A05:2021 Security Misconfiguration
MITRE ATT&CK (indicative)	n/a
Validation status	**VALIDATED** · confidence 90/100 (high) Validation: confirmed by argus-http-check - No Content-Security-Policy header in the response. [EV-0016]
Priority	5.5 (rank 5)

OBSERVED (tool evidence): Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
Reported by: zap (LIVE) [EV-0004] rule zap:10038, nikto (LIVE) [EV-0007] rule nikto:013587

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +25 independently reported by 2 tools (nikto, zap) | zap-confidence:High | validation: confirmed by argus-http-check: No Content-Security-Policy header in the response.
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

F-025 — Absence of Anti-CSRF Tokens

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/vulnerabilities/javascript/
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-352 / A01:2021 Broken Access Control
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100 (medium)
Priority	5.2 (rank 6)

OBSERVED (tool evidence): No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session ri
Reported by: zap (LIVE) [EV-0003] rule zap:10202, zap (LIVE) [EV-0018] rule zap:10202

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Low
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-006 — Missing Anti-clickjacking Header

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/login.php, http://10.77.0.10/setup.php, http://10.77.0.10/, http://10.77.0.10 Parameter: x-frame-options
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: 4.3 CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N (source: nessus)
CVE / CWE / OWASP	none reported / CWE-1021 / A05:2021 Security Misconfiguration
MITRE ATT&CK (indicative)	n/a
Validation status	**VALIDATED** · confidence 90/100 (high) Validation: confirmed by argus-http-check - Neither X-Frame-Options nor a CSP frame-ancestors directive is present in the response. [EV-0010]
Priority	4.8 (rank 7)

OBSERVED (tool evidence): The remote web server does not set an X-Frame-Options response header or a Content-Security-Policy 'frame-ancestors' response header in all content responses. Plugin output: The following pages do not set a X-Frame-Options HTTP response header : http://10.77.0.10/
Reported by: zap (LIVE) [EV-0003] rule zap:10020, zap (LIVE) [EV-0018] rule zap:10020, nessus (IMPORT) [EV-0020] rule nessus:85582

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +25 independently reported by 2 tools (nessus, zap) | zap-confidence:Medium
Risk factors: base 4.3 (CVSS 4.3 reported by nessus); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

F-011 — Application Error Disclosure

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/dvwa/css/, http://10.77.0.10/dvwa/, http://10.77.0.10/dvwa/images/, http://10.77.0.10/dvwa/images/?C=N;O=D
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-550 / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100 (medium)
Priority	4.7 (rank 8)

OBSERVED (tool evidence): This page contains an error/warning message that may disclose sensitive information like the location of the file that produced the unhandled exception. This information can be used to launch further attacks against the web application. The alert could be a false positive if the error message is found inside a documentation page. Evidence: HTTP/1.0 500 Internal Server Error
Reported by: zap (LIVE) [EV-0003] rule zap:90022, zap (LIVE) [EV-0018] rule zap:90022

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Medium
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-014 — Absence of Anti-CSRF Tokens

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/vulnerabilities/exec/
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-352 / A01:2021 Broken Access Control
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100 (medium)
Priority	4.7 (rank 9)

OBSERVED (tool evidence): No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session ri
Reported by: zap (LIVE) [EV-0003] rule zap:10202, zap (LIVE) [EV-0018] rule zap:10202

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Low
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-015 — Absence of Anti-CSRF Tokens

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/vulnerabilities/xss_s/
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-352 / A01:2021 Broken Access Control
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100 (medium)
Priority	4.7 (rank 10)

OBSERVED (tool evidence): No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session ri
Reported by: zap (LIVE) [EV-0003] rule zap:10202, zap (LIVE) [EV-0018] rule zap:10202

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Low
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-017 — Absence of Anti-CSRF Tokens

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/vulnerabilities/captcha/
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-352 / A01:2021 Broken Access Control
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100 (medium)
Priority	4.7 (rank 11)

OBSERVED (tool evidence): No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session ri
Reported by: zap (LIVE) [EV-0003] rule zap:10202, zap (LIVE) [EV-0018] rule zap:10202

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Low
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-018 — Sub Resource Integrity Attribute Missing

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/vulnerabilities/captcha/
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-345 / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100 (medium)
Priority	4.7 (rank 12)

OBSERVED (tool evidence): The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content. Evidence: <script src='https://www.google.com/recaptcha/api.js'></script>
Reported by: zap (LIVE) [EV-0003] rule zap:90003, zap (LIVE) [EV-0018] rule zap:90003

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:High
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-019 — Absence of Anti-CSRF Tokens

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/vulnerabilities/upload/
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-352 / A01:2021 Broken Access Control
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100 (medium)
Priority	4.7 (rank 13)

OBSERVED (tool evidence): No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session ri
Reported by: zap (LIVE) [EV-0003] rule zap:10202, zap (LIVE) [EV-0018] rule zap:10202

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Low
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-020 — CSP: Failure to Define Directive with No Fallback

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/vulnerabilities/csp/ Parameter: Content-Security-Policy
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-693 / A05:2021 Security Misconfiguration
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100 (medium)
Priority	4.7 (rank 14)

OBSERVED (tool evidence): The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything. Evidence: script-src 'self' https://pastebin.com example.com code.jquery.com https://ssl.google-analytics.com ;
Reported by: zap (LIVE) [EV-0003] rule zap:10055, zap (LIVE) [EV-0018] rule zap:10055

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:High
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-021 — CSP: Wildcard Directive

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/vulnerabilities/csp/ Parameter: Content-Security-Policy
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-693 / A05:2021 Security Misconfiguration
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100 (medium)
Priority	4.7 (rank 15)

OBSERVED (tool evidence): Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files. Evidence: script-src 'self' https://pastebin.com example.com code.jquery.com https://ssl
Reported by: zap (LIVE) [EV-0003] rule zap:10055, zap (LIVE) [EV-0018] rule zap:10055

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:High
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-022 — CSP: style-src unsafe-inline

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/vulnerabilities/csp/ Parameter: Content-Security-Policy
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-693 / A05:2021 Security Misconfiguration
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100 (medium)
Priority	4.7 (rank 16)

OBSERVED (tool evidence): Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files. Evidence: script-src 'self' https://pastebin.com example.com code.jquery.com https://ssl
Reported by: zap (LIVE) [EV-0003] rule zap:10055, zap (LIVE) [EV-0018] rule zap:10055

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:High
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-023 — Absence of Anti-CSRF Tokens

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/vulnerabilities/csp/
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-352 / A01:2021 Broken Access Control
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100 (medium)
Priority	4.7 (rank 17)

OBSERVED (tool evidence): No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session ri
Reported by: zap (LIVE) [EV-0003] rule zap:10202, zap (LIVE) [EV-0018] rule zap:10202

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Low
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-024 — Absence of Anti-CSRF Tokens

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/vulnerabilities/weak_id/
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-352 / A01:2021 Broken Access Control
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100 (medium)
Priority	4.7 (rank 18)

OBSERVED (tool evidence): No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session ri
Reported by: zap (LIVE) [EV-0003] rule zap:10202, zap (LIVE) [EV-0018] rule zap:10202

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Low
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-031 — Cross-Domain Misconfiguration

Affected asset	10.77.0.11:3000 URLs: http://10.77.0.11:3000/robots.txt, http://10.77.0.11:3000/rolldown-runtime-BoHGiXSq.js, http://10.77.0.11:3000/chunk-DBPdFzgj.js, http://10.77.0.11:3000/assets/public/favicon_js.ico
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-264 / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100 (medium)
Priority	4.7 (rank 19)

OBSERVED (tool evidence): Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server. Evidence: Access-Control-Allow-Origin: *
Reported by: zap (LIVE) [EV-0004] rule zap:10098

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Medium
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-003 — Cookie No HttpOnly Flag

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10, http://10.77.0.10/login.php Parameter: PHPSESSID
Severity / CVSS	**LOW** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-1004 / A05:2021 Security Misconfiguration
MITRE ATT&CK (indicative)	n/a
Validation status	**VALIDATED** · confidence 90/100 (high) Validation: confirmed by argus-http-check - Cookie(s) PHPSESSID, PHPSESSID, security lack the httponly attribute. [EV-0008]
Priority	3.0 (rank 20)

OBSERVED (tool evidence): A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible. Evidence: Set-Cookie: PHPSESSID
Reported by: zap (LIVE) [EV-0003] rule zap:10010, zap (LIVE) [EV-0018] rule zap:10010, burp (IMPORT) [EV-0021] rule burp:5244416

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +25 independently reported by 2 tools (burp, zap) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Medium | burp-confidence:Firm
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

F-054 — Web Server Transmits Cleartext Credentials

Affected asset	10.77.0.10:80
Severity / CVSS	**LOW** (reported by nessus) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-523 / A02:2021 Cryptographic Failures
MITRE ATT&CK (indicative)	T1040
Validation status	**OBSERVED** · confidence 35/100 (low)
Priority	2.6 (rank 21)

OBSERVED (tool evidence): The remote web server contains several forms that are susceptible to submit their data over HTTP cleartext instead of HTTPS. Plugin output: Page : /login.php Destination Page: /login.php
Reported by: nessus (IMPORT) [EV-0020] rule nessus:26194

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | -5 only from an imported file (not re-executed by ARGUS)
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (nessus)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-005 — Cookie without SameSite Attribute

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10 Parameter: PHPSESSID
Severity / CVSS	**LOW** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-1275 / A01:2021 Broken Access Control
MITRE ATT&CK (indicative)	n/a
Validation status	**VALIDATED** · confidence 90/100 (high) Validation: confirmed by argus-http-check - Cookie(s) PHPSESSID, PHPSESSID, security lack the samesite attribute. [EV-0009]
Priority	2.5 (rank 22)

OBSERVED (tool evidence): A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks. Evidence: Set-Cookie: PHPSESSID
Reported by: zap (LIVE) [EV-0003] rule zap:10054, zap (LIVE) [EV-0018] rule zap:10054

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Medium
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

F-007 — Server Leaks Version Information via "Server" HTTP Response Header Field

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/sitemap.xml, http://10.77.0.10/dvwa/css/login.css, http://10.77.0.10/robots.txt, http://10.77.0.10/dvwa/images/RandomStorm.png
Severity / CVSS	**LOW** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-497 / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**VALIDATED** · confidence 90/100 (high) Validation: confirmed by argus-http-check - Response discloses software version: 'Apache/2.4.25 (Debian)'. [EV-0011]
Priority	2.5 (rank 23)

OBSERVED (tool evidence): The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.
Evidence: Apache/2.4.25 (Debian)
Reported by: zap (LIVE) [EV-0003] rule zap:10036, zap (LIVE) [EV-0018] rule zap:10036

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:High
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

F-008 — X-Content-Type-Options Header Missing

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/dvwa/css/login.css, http://10.77.0.10/dvwa/images/RandomStorm.png, http://10.77.0.10/robots.txt, http://10.77.0.10/dvwa/images/login_logo.png Parameter: x-content-type-options
Severity / CVSS	**LOW** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-693 / A05:2021 Security Misconfiguration
MITRE ATT&CK (indicative)	n/a
Validation status	**VALIDATED** · confidence 90/100 (high) Validation: confirmed by argus-http-check - X-Content-Type-Options header is absent. [EV-0013]
Priority	2.5 (rank 24)

OBSERVED (tool evidence): The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
Reported by: zap (LIVE) [EV-0003] rule zap:10021, nikto (LIVE) [EV-0006] rule nikto:013587, nikto (LIVE) [EV-0006] rule nikto:007352, zap (LIVE) [EV-0018] rule zap:10021

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +25 independently reported by 2 tools (nikto, zap) | zap-confidence:Medium
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

F-034 — Apache/2.4.25 appears to be outdated (current is at least 2.4.68).

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10:80/
Severity / CVSS	**LOW** (reported by derived from nikto message) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-1104 / A06:2021 Vulnerable and Outdated Components
MITRE ATT&CK (indicative)	T1190
Validation status	**VALIDATED** · confidence 90/100 (high) Validation: confirmed by metasploit-aux - read-only module re-read version '2.4.25' from the live service [EV-0019]
Priority	2.5 (rank 25)

OBSERVED (tool evidence): Nikto test 600050 (HEAD /): Apache/2.4.25 appears to be outdated (current is at least 2.4.68).
Reported by: nikto (LIVE) [EV-0006] rule nikto:600050

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | validation: confirmed by metasploit-aux: read-only module re-read version '2.4.25' from the live service
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (derived from nikto message)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

F-056 — TCP Timestamps Information Disclosure

Affected asset	10.77.0.10:-
Severity / CVSS	**LOW** (reported by openvas) · CVSS: 2.6 (source: openvas)
CVE / CWE / OWASP	none reported / n/a / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 35/100 (low)
Priority	2.2 (rank 26)

OBSERVED (tool evidence): The remote host implements TCP timestamps and therefore allows to compute the uptime.
Reported by: openvas (IMPORT) [EV-0022] rule openvas:1.3.6.1.4.1.25623.1.0.80091

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | -5 only from an imported file (not re-executed by ARGUS)
Risk factors: base 2.6 (CVSS 2.6 reported by openvas); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-004 — In Page Banner Information Leak

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/sitemap.xml, http://10.77.0.10/var/www/html/config/config.inc.php, http://10.77.0.10/DTD/xhtml1-transitional.dtd, http://10.77.0.10/DTD
Severity / CVSS	**LOW** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-497 / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100 (medium)
Priority	2.1 (rank 27)

OBSERVED (tool evidence): The server returned a version banner string in the response content. Such information leaks may allow attackers to further target specific issues impacting the product and version in use. Evidence: Apache/2.4.25
Reported by: zap (LIVE) [EV-0003] rule zap:10009, zap (LIVE) [EV-0018] rule zap:10009

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:High
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-013 — Information Disclosure - Debug Error Messages

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/instructions.php, http://10.77.0.10/instructions.php?doc=readme
Severity / CVSS	**LOW** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-1295 / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100 (medium)
Priority	2.1 (rank 28)

OBSERVED (tool evidence): The response appeared to contain common error messages returned by platforms such as ASP.NET, and Web-servers such as IIS and Apache. You can configure the list of common debug messages. Evidence: PHP warning
Reported by: zap (LIVE) [EV-0003] rule zap:10023, zap (LIVE) [EV-0018] rule zap:10023

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Medium
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-016 — Cross-Domain JavaScript Source File Inclusion

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/vulnerabilities/captcha/ Parameter: https://www.google.com/recaptcha/api.js
Severity / CVSS	**LOW** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-829 / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100 (medium)
Priority	2.1 (rank 29)

OBSERVED (tool evidence): The page includes one or more script files from a third-party domain. Evidence: <script src='https://www.google.com/recaptcha/api.js'></script>
Reported by: zap (LIVE) [EV-0003] rule zap:10017, zap (LIVE) [EV-0018] rule zap:10017

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Medium
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-026 — Timestamp Disclosure - Unix

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/vulnerabilities/javascript/, http://10.77.0.10/phpinfo.php
Severity / CVSS	**LOW** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-497 / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100 (medium)
Priority	2.1 (rank 30)

OBSERVED (tool evidence): A timestamp was disclosed by the application/web server. - Unix Evidence: 1732584193
Reported by: zap (LIVE) [EV-0003] rule zap:10096, zap (LIVE) [EV-0018] rule zap:10096

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Low
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-028 — Private IP Disclosure

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/phpinfo.php
Severity / CVSS	**LOW** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-497 / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100 (medium)
Priority	2.1 (rank 31)

OBSERVED (tool evidence): A private IP (such as 10.x.x.x, 172.x.x.x, 192.168.x.x) or an Amazon EC2 private hostname (for example, ip-10-0-56-78) has been found in the HTTP response body. This information might be helpful for further attacks targeting internal systems. Evidence: 10.77.0.3
Reported by: zap (LIVE) [EV-0003] rule zap:2, zap (LIVE) [EV-0018] rule zap:2

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Medium
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-035 — Suggested security header missing: permissions-policy.

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10:80/
Severity / CVSS	**LOW** (reported by derived from nikto message) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / n/a / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 40/100 (medium)
Priority	2.1 (rank 32)

OBSERVED (tool evidence): Nikto test 013587 (GET /): Suggested security header missing: permissions-policy.
Reported by: nikto (LIVE) [EV-0006] rule nikto:013587

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only)
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (derived from nikto message)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-037 — Suggested security header missing: referrer-policy.

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10:80/
Severity / CVSS	**LOW** (reported by derived from nikto message) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / n/a / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 40/100 (medium)
Priority	2.1 (rank 33)

OBSERVED (tool evidence): Nikto test 013587 (GET /): Suggested security header missing: referrer-policy.
Reported by: nikto (LIVE) [EV-0006] rule nikto:013587

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only)
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (derived from nikto message)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-047 — Suggested security header missing: permissions-policy.

Affected asset	10.77.0.11:3000 URLs: http://10.77.0.11:3000/
Severity / CVSS	**LOW** (reported by derived from nikto message) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / n/a / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 40/100 (medium)
Priority	2.1 (rank 34)

OBSERVED (tool evidence): Nikto test 013587 (GET /): Suggested security header missing: permissions-policy.
Reported by: nikto (LIVE) [EV-0007] rule nikto:013587

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only)
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (derived from nikto message)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-048 — Suggested security header missing: referrer-policy.

Affected asset	10.77.0.11:3000 URLs: http://10.77.0.11:3000/
Severity / CVSS	**LOW** (reported by derived from nikto message) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / n/a / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 40/100 (medium)
Priority	2.1 (rank 35)

OBSERVED (tool evidence): Nikto test 013587 (GET /): Suggested security header missing: referrer-policy.
Reported by: nikto (LIVE) [EV-0007] rule nikto:013587

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only)
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (derived from nikto message)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

5. Impact and Remediation

ID	Technical / business impact	Recommended remediation	References
F-055	Attacker script can run in a victim's browser: session theft, defacement, phishing.	Encode output according to context and validate input.	CWE-79
F-030	Data theft or modification, potential full database compromise.	Do not trust client side input, even if there is client side validation in place. In general, type check all data on the server side. If the application uses JDBC, use PreparedStatement or CallableStatement, with parameters passed by '?' If the application uses ASP, use ADO Command Objects with strong type checking and parameterized queries. If database Stored Procedures can be used, use them. Do *not* concatenate strings into queries in the stored procedure, or use 'exec', 'exec immediate', or equivalent functionality! Do not create dynamic SQL queries using simple string concatenation. Escape all data received from the client. Apply an 'allow list' of allowed characters, or a 'deny list' of disallowed characters in user input. Apply the principle of least privilege by using the least privileged database user possible. In particular, avoid using the 'sa' or 'db-owner' database users. This does not eliminate SQL injection, but minimizes its impact. Grant the minimum database access that is necessary for the application.	https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html
F-002	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.	https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html; https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
F-012	Reveals file structure and potentially sensitive files to anyone.	Configure the web server to disable directory browsing.	CWE-548; https://cwe.mitre.org/data/definitions/548.html
F-032	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.	https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html; https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP

ID	Technical / business impact	Recommended remediation	References
F-025	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. For example, use anti-CSRF packages such as the OWASP CSRFGuard. Phase: Implementation Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script. Phase: Architecture and Design Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330). Note that this can be bypassed using XSS. Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation. Note that this can be bypassed using XSS. Use the ESAPI Session Management control. This control includes a component for CSRF. Do not use the GET method for any request that triggers a state change. Phase: Implementation Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons.	https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html; https://cwe.mitre.org/data/definitions/352.html
F-006	Users can be tricked into clicking hidden UI; may enable unwanted actions in an authenticated session.	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
F-011	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Review the source code of this page. Implement custom error pages. Consider implementing a mechanism to provide a unique error reference/identifier to the client (browser) while logging the details on the server side and not exposing them to the user.	CWE-550

ID	Technical / business impact	Recommended remediation	References
F-014	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. For example, use anti-CSRF packages such as the OWASP CSRFGuard. Phase: Implementation Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script. Phase: Architecture and Design Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330). Note that this can be bypassed using XSS. Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation. Note that this can be bypassed using XSS. Use the ESAPI Session Management control. This control includes a component for CSRF. Do not use the GET method for any request that triggers a state change. Phase: Implementation Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons.	https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html; https://cwe.mitre.org/data/definitions/352.html
F-015	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. For example, use anti-CSRF packages such as the OWASP CSRFGuard. Phase: Implementation Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script. Phase: Architecture and Design Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330). Note that this can be bypassed using XSS. Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation. Note that this can be bypassed using XSS. Use the ESAPI Session Management control. This control includes a component for CSRF. Do not use the GET method for any request that triggers a state change. Phase: Implementation Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons.	https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html; https://cwe.mitre.org/data/definitions/352.html

ID	Technical / business impact	Recommended remediation	References
F-017	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. For example, use anti-CSRF packages such as the OWASP CSRFGuard. Phase: Implementation Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script. Phase: Architecture and Design Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330). Note that this can be bypassed using XSS. Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation. Note that this can be bypassed using XSS. Use the ESAPI Session Management control. This control includes a component for CSRF. Do not use the GET method for any request that triggers a state change. Phase: Implementation Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons.	https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html; https://cwe.mitre.org/data/definitions/352.html
F-018	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Provide a valid integrity attribute to the tag.	https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity

ID	Technical / business impact	Recommended remediation	References
F-019	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. For example, use anti-CSRF packages such as the OWASP CSRFGuard. Phase: Implementation Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script. Phase: Architecture and Design Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330). Note that this can be bypassed using XSS. Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation. Note that this can be bypassed using XSS. Use the ESAPI Session Management control. This control includes a component for CSRF. Do not use the GET method for any request that triggers a state change. Phase: Implementation Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons.	https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html; https://cwe.mitre.org/data/definitions/352.html
F-020	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.	https://caniuse.com/#search=content+security+policy; https://content-security-policy.com/
F-021	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.	https://caniuse.com/#search=content+security+policy; https://content-security-policy.com/
F-022	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.	https://caniuse.com/#search=content+security+policy; https://content-security-policy.com/

ID	Technical / business impact	Recommended remediation	References
F-023	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. For example, use anti-CSRF packages such as the OWASP CSRFGuard. Phase: Implementation Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script. Phase: Architecture and Design Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330). Note that this can be bypassed using XSS. Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation. Note that this can be bypassed using XSS. Use the ESAPI Session Management control. This control includes a component for CSRF. Do not use the GET method for any request that triggers a state change. Phase: Implementation Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons.	https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html; https://cwe.mitre.org/data/definitions/352.html
F-024	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. For example, use anti-CSRF packages such as the OWASP CSRFGuard. Phase: Implementation Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script. Phase: Architecture and Design Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330). Note that this can be bypassed using XSS. Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation. Note that this can be bypassed using XSS. Use the ESAPI Session Management control. This control includes a component for CSRF. Do not use the GET method for any request that triggers a state change. Phase: Implementation Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons.	https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html; https://cwe.mitre.org/data/definitions/352.html

ID	Technical / business impact	Recommended remediation	References
F-031	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.	https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy
F-003	Script (e.g. via XSS) can read the session cookie, enabling account takeover.	Ensure that the HttpOnly flag is set for all cookies.	https://owasp.org/www-community/HttpOnly
F-054	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Make sure that every sensitive form transmits content over HTTPS.	CWE-523
F-005	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.	https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site
F-007	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.	https://httpd.apache.org/docs/current/mod/core.html#servertokens; https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10)
F-008	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options; https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)
F-034	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Upgrade to a currently supported release and apply vendor security updates.	CWE-1104
F-056	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Disable TCP timestamps on the host or filter them at the network boundary.	-
F-004	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Configure the server to prevent such information leaks. For example: Under Tomcat this is done via the "server" directive and implementation of custom error pages. Under Apache this is done via the "ServerSignature" and "ServerTokens" directives.	https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/08-Testing_for_Error_Handling/
F-013	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Disable debugging messages before pushing to production.	CWE-1295
F-016	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be controlled by end users of the application.	CWE-829

ID	Technical / business impact	Recommended remediation	References
F-026	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.	https://cwe.mitre.org/data/definitions/200.html
F-028	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Remove the private IP address from the HTTP response body. For comments, use JSP/ASP/PHP comment instead of HTML/JavaScript comment which can be seen by client browsers.	https://datatracker.ietf.org/doc/html/rfc1918
F-035	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	See tool guidance; no automated recommendation available.	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
F-037	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	See tool guidance; no automated recommendation available.	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
F-047	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	See tool guidance; no automated recommendation available.	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
F-048	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	See tool guidance; no automated recommendation available.	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy

6. Assessment Limitations, Assumptions and Human Approvals

• nessus data in this report is IMPORTED from 'SAMPLE-sample_nessus_dvwa.nessus' and was not executed by ARGUS.
• burp data in this report is IMPORTED from 'SAMPLE-sample_burp_dvwa.xml' and was not executed by ARGUS.
• openvas data in this report is IMPORTED from 'SAMPLE-sample_openvas_dvwa.xml' and was not executed by ARGUS.
• 3 finding(s) in oos.nessus were dropped: their hosts are outside the authorized scope (8.8.8.8).
• nessus data in this report is IMPORTED from 'oos.nessus' and was not executed by ARGUS.
• Findings are limited to what the integrated tools could observe; absence of a finding is not proof of absence.
• Exposure is assumed to be 'reachable over the network without authentication' for all lab assets; asset criticality defaulted to 1.0 unless set by the analyst.
• The CISA KEV check uses a small partial offline snapshot; CVE-to-version mapping uses a small reference table.
• Some data was imported from files (marked IMPORT). Imported data was not re-executed by ARGUS; sample import files are synthetic test inputs if so named.
• Grounding check of the narrative text (cited evidence ids exist; no CVE or CVSS value that no tool reported): **PASSED**.

Human approvals (active validation)

ID	Action	Status	Decided by	Decided at	Comment / outcome
AP-001	zap_active:http://10.77.0.10	EXECUTED	e2e-tester	2026-11-07T07:18:32	lab only, e2e test / executed: 381 raw finding(s); ZAP discovered 114 URLs; active scan was capped at 4 minute
AP-002	msf_check:F-034:options	REJECTED	e2e-tester	2026-11-07T07:21:46	reject test / rejected by analyst; not executed
AP-003	msf_check:F-034:http_version	EXECUTED	e2e-tester	2026-11-07T07:21:55	read-only banner check / executed: 0 raw finding(s); [+] 10.77.0.10:80 Apache/2.4.25 (Debian) (302-login.php

Assessment timestamps: first audit event 2026-11-07T07:14:01+00:00, last 2026-11-07T07:24:15+00:00 (UTC).

Appendix A. Evidence index (traceability)

Every finding ID above links to evidence IDs here. Each file's SHA-256 was computed when it was captured; the raw file is available in the ARGUS data folder.

Evidence	Tool	Mode	Captured (UTC)	File	SHA-256	Locator
EV-0001	nmap	LIVE	2026-11-07T07:14:21	artifacts/A-14ca676a/J-001_nmap.xml	a372840e33d8b3da...	nmaprun
EV-0002	nmap	LIVE	2026-11-07T07:14:31	artifacts/A-14ca676a/J-002_nmap.xml	0a566c67e5321995...	nmaprun
EV-0003	zap	LIVE	2026-11-07T07:14:39	artifacts/A-14ca676a/J-003_zap.json	df6350f298a44030...	$.alerts
EV-0004	zap	LIVE	2026-11-07T07:15:06	artifacts/A-14ca676a/J-004_zap.json	740fb9be4e166759...	$.alerts
EV-0005	nmap	LIVE	2026-11-07T07:15:23	artifacts/A-14ca676a/J-005_nmap.xml	f2f29203811a6afc...	nmaprun
EV-0006	nikto	LIVE	2026-11-07T07:15:33	rtifacts/A-14ca676a/J-006_nikto.json	a3b5f20afd3373d2...	$.vulnerabilities
EV-0007	nikto	LIVE	2026-11-07T07:18:11	rtifacts/A-14ca676a/J-009_nikto.json	218e4ade58910f6f...	$.vulnerabilities
EV-0008	argus-http-check	LIVE	2026-11-07T07:18:17	ifacts/A-14ca676a/J-012_validate.txt	08b62c6c08d14d8b...	response headers
EV-0009	argus-http-check	LIVE	2026-11-07T07:18:17	ifacts/A-14ca676a/J-013_validate.txt	b314836b54bf0586...	response headers
EV-0010	argus-http-check	LIVE	2026-11-07T07:18:18	ifacts/A-14ca676a/J-014_validate.txt	217ec4856234fc25...	response headers
EV-0011	argus-http-check	LIVE	2026-11-07T07:18:18	ifacts/A-14ca676a/J-015_validate.txt	120f842ef6f66d5e...	response headers
EV-0012	argus-http-check	LIVE	2026-11-07T07:18:18	ifacts/A-14ca676a/J-016_validate.txt	f3693733b518b244...	response headers
EV-0013	argus-http-check	LIVE	2026-11-07T07:18:19	ifacts/A-14ca676a/J-017_validate.txt	d34e35f8096bdf76...	response headers
EV-0014	argus-http-check	LIVE	2026-11-07T07:18:19	ifacts/A-14ca676a/J-018_validate.txt	571ba9190b4f0f0b...	response headers
EV-0015	argus-http-check	LIVE	2026-11-07T07:18:19	ifacts/A-14ca676a/J-019_validate.txt	7177e27693a1bac4...	response headers
EV-0016	argus-http-check	LIVE	2026-11-07T07:18:20	ifacts/A-14ca676a/J-020_validate.txt	b658042de90d18f8...	response headers
EV-0017	argus-http-check	LIVE	2026-11-07T07:18:20	ifacts/A-14ca676a/J-021_validate.txt	419c48102215636e...	response headers
EV-0018	zap	LIVE	2026-11-07T07:21:31	artifacts/A-14ca676a/J-022_zap.json	d085181f799151db...	$.alerts
EV-0019	metasploit	LIVE	2026-11-07T07:22:34	artifacts/A-14ca676a/J-023_msf.txt	b62d2ac32a4c9984...	stdout
EV-0020	nessus	IMPORT	2026-11-07T07:22:43	sus_SAMPLE-sample_nessus_dvwa.nessus	7886ec8c9c3bbcd6...	file
EV-0021	burp	IMPORT	2026-11-07T07:22:46	76a/burp_SAMPLE-sample_burp_dvwa.xml	afd369a88257e3c1...	file
EV-0022	openvas	IMPORT	2026-11-07T07:22:49	envas_SAMPLE-sample_openvas_dvwa.xml	1ddf666d5d954283...	file

Evidence	Tool	Mode	Captured (UTC)	File	SHA-256	Locator
EV-0023	nessus	IMPORT	2026-11-07T07:22:55	tifacts/A-14ca676a/nessus_oos.nessus	d8af3a9f8ece157a...	file
EV-0024	nessus	IMPORT	2026-11-07T07:23:00	tifacts/A-14ca676a/nessus_bad.nessus	22f81c28a81ea234...	file
EV-0025	argus-http-check	LIVE	2026-11-07T07:23:07	rtifacts/A-14ca676a/J-024_retest.txt	381a727384a00bb3...	response headers

Appendix B. Refuted alerts (false positives)

ID	Alert	Asset	Why refuted	Evidence
F-036	Suggested security header missing: strict-transport-security	10.77.0.10:80	The service is plain HTTP. Browsers ignore Strict-Transport-Security on HTTP, so this check does not apply until HTTPS is enabled.	EV-0006, EV-0012
F-049	Suggested security header missing: strict-transport-security	10.77.0.11:3000	The service is plain HTTP. Browsers ignore Strict-Transport-Security on HTTP, so this check does not apply until HTTPS is enabled.	EV-0007, EV-0017

Appendix C. Agent decision log

D-001 [scope] planner: rules · chose: nmap_scan:10.77.0.0/24
Reasoning: No hosts or services are known yet. Service discovery is the prerequisite for choosing every other tool.
Scope check: 10.77.0.0/24: in scope
Outcome: pending

D-002 [recon] planner: gemini · chose: nmap_scan:10.77.0.0/24
Reasoning: No hosts or services are known yet in the current state. Performing an initial network scan is the necessary first step to discover active hosts and services before formulating specific hypotheses.
Scope check: nmap/standard on 10.77.0.0/24 allowed
Outcome: completed: 0 raw finding(s), total findings 0 -> 0

D-003 [enumeration] planner: gemini · chose: nmap_enum:10.77.0.10
Reasoning: Given the target 10.77.0.10 running an Apache web server on port 80, running low-noise Nmap enumeration scripts will cheaply identify potential misconfigurations and paths. This directly addresses the hypothesis regarding the web service on 10.77.0.10 before committing to heavier scanning tools.
Scope check: nmap/standard on 10.77.0.10 allowed
Outcome: completed: 0 raw finding(s), total findings 0 -> 0

D-004 [vulnerability-analysis] planner: gemini · chose: zap_passive:http://10.77.0.10
Reasoning: The host 10.77.0.10 runs an Apache httpd 2.4.25 web service on port 80. Running ZAP passive analysis will efficiently map the application and identify potential misconfigurations or vulnerabilities without generating excessive network noise.
Scope check: zap/standard on 10.77.0.10 allowed
Outcome: completed: 379 raw finding(s), total findings 0 -> 30

D-005 [vulnerability-analysis] planner: gemini · chose: zap_passive:http://10.77.0.11:3000
Reasoning: The service on 10.77.0.11:3000 is identified as a web application under open hypotheses. Running zap_passive on http://10.77.0.11:3000 will map the application and investigate misconfigurations at low noise and medium cost.
Scope check: zap/standard on 10.77.0.11 allowed
Outcome: completed: 238 raw finding(s), total findings 30 -> 33

D-006 [enumeration] planner: gemini · chose: nmap_enum:10.77.0.11
Reasoning: Service discovery indicates port 3000 on 10.77.0.11 is running ppp/HTTP, but no deep enumeration or web scans have been performed on this asset yet. Running nmap enumeration will identify service details and web paths at a low cost and noise level.
Scope check: nmap/standard on 10.77.0.11 allowed
Outcome: completed: 0 raw finding(s), total findings 33 -> 33

D-007 [vulnerability-analysis] planner: gemini · chose: nikto:http://10.77.0.10
Reasoning: Target 10.77.0.10 hosts Apache httpd 2.4.25 and has multiple findings including a high-severity SQL injection (F-030). Running Nikto against http://10.77.0.10 helps discover additional server misconfigurations and known files to further evaluate the attack surface.
Scope check: nikto/standard on 10.77.0.10 allowed
Outcome: completed: 14 raw finding(s), total findings 33 -> 42

D-008 [vulnerability-analysis] planner: rules · chose: nikto:http://10.77.0.11:3000
Reasoning: http://10.77.0.11:3000 serves HTTP: Nikto checks server configuration and known files; complements ZAP, and a second tool lets findings be cross-checked.
Scope check: nikto/standard on 10.77.0.11 allowed
Outcome: completed: 15 raw finding(s), total findings 42 -> 53

D-009 [triage] planner: gemini · chose: validate:F-003, validate:F-005, validate:F-006, validate:F-007, validate:F-036, validate:F-008, validate:F-002, validate:F-012, validate:F-032, validate:F-049
Reasoning: 10 configuration findings can each be confirmed or refuted with one harmless GET. Doing this before ranking removes false positives so they do not distort priorities.
Scope check: nmap/standard on 10.77.0.10 allowed
Outcome: validation verdicts: F-003: confirmed; F-005: confirmed; F-006: confirmed; F-007: confirmed; F-036: refuted; F-008: confirmed; F-002: confirmed; F-012: confirmed; F-032: confirmed; F-049: refuted

D-010 [import] planner: analyst · chose: import:SAMPLE-sample_nessus_dvwa.nessus
Reasoning: Imported 3 in-scope finding(s): 1 new, 2 merged with existing findings; 0 out-of-scope dropped.
Scope check:
Outcome: IMPORT only: no scan was executed for this tool.

D-011 [import] planner: analyst · chose: import:SAMPLE-sample_burp_dvwa.xml
Reasoning: Imported 2 in-scope finding(s): 1 new, 1 merged with existing findings; 0 out-of-scope dropped.
Scope check:
Outcome: IMPORT only: no scan was executed for this tool.

D-012 [import] planner: analyst · chose: import:SAMPLE-sample_openvas_dvwa.xml
Reasoning: Imported 1 in-scope finding(s): 1 new, 0 merged with existing findings; 0 out-of-scope dropped.
Scope check:
Outcome: IMPORT only: no scan was executed for this tool.

D-013 [import] planner: analyst · chose: import:oos.nessus
Reasoning: Imported 0 in-scope finding(s): 0 new, 0 merged with existing findings; 3 out-of-scope dropped.
Scope check:
Outcome: IMPORT only: no scan was executed for this tool.

Appendix E. Informational observations

Items reported by tools at informational level. They are context, not vulnerabilities, and are not ranked.

ID	Observation	Asset	Source	Evidence
F-001	Session Management Response Identified	10.77.0.10:80	zap	EV-0003, EV-0018
F-009	Authentication Request Identified	10.77.0.10:80	zap	EV-0003, EV-0018
F-010	Information Disclosure - Suspicious Comments	10.77.0.10:80	zap	EV-0003, EV-0018
F-027	Information Disclosure - Sensitive Information in URL	10.77.0.10:80	zap	EV-0003, EV-0018
F-029	Modern Web Application	10.77.0.10:80	zap	EV-0003, EV-0018
F-033	Modern Web Application	10.77.0.11:3000	zap	EV-0004
F-038	Configuration information may be available remotely.	10.77.0.10:80	nikto	EV-0006
F-039	Apache default file found.	10.77.0.10:80	nikto	EV-0006
F-040	Admin login page/section found.	10.77.0.10:80	nikto	EV-0006
F-041	.gitignore file found. It is possible to grasp the directory structure.	10.77.0.10:80	nikto	EV-0006
F-042	X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTT	10.77.0.10:80	nikto	EV-0006
F-043	Retrieved access-control-allow-origin header: *.	10.77.0.11:3000	nikto	EV-0007
F-044	Uncommon header(s) 'x-recruiting' found, with contents: /#/jobs.	10.77.0.11:3000	nikto	EV-0007
F-045	/robots.txt: Entry '/ftp/' is returned a non-forbidden or redirect HTTP code (200).	10.77.0.11:3000	nikto	EV-0007
F-046	contains 1 entry which should be manually viewed.	10.77.0.11:3000	nikto	EV-0007
F-050	This might be interesting.	10.77.0.11:3000	nikto	EV-0007
F-051	Contains authorization information.	10.77.0.11:3000	nikto	EV-0007
F-052	A user's home directory may be set to the web root, the shell history was retrieved. This	10.77.0.11:3000	nikto	EV-0007
F-053	Database SQL?.	10.77.0.11:3000	nikto	EV-0007

Appendix D. Audit trail (hash-chained)

Chain verification: INTACT.

#	Time (UTC)	Actor	Action	Hash
741	2026-11-07T07:14:01	analyst	assessment.create	8d48cd7bb3efa0
742	2026-11-07T07:14:01	scope-guard	scope.check	362eb61e1e8501
743	2026-11-07T07:14:02	agent	plan.proposed	220bf5f166b8f2
744	2026-11-07T07:14:04	e2e-tester	plan.approved	71b75eef2fdc18
745	2026-11-07T07:14:05	agent	decision	8297f2d657bac6
746	2026-11-07T07:14:05	agent	action.start	689997f643bf8c
747	2026-11-07T07:14:21	agent	action.done	c0533cc70ddb1b
748	2026-11-07T07:14:23	agent	decision	baf7f8403d3238
749	2026-11-07T07:14:23	agent	action.start	416352d34884e4
750	2026-11-07T07:14:31	agent	action.done	4c3e7ec755ab07
751	2026-11-07T07:14:32	agent	decision	9a9f33ade2dfa1
752	2026-11-07T07:14:32	agent	action.start	f80278c3f10a41
753	2026-11-07T07:14:39	agent	action.done	c10b924820cf7e
754	2026-11-07T07:14:42	agent	decision	17f614414975b9
755	2026-11-07T07:14:42	agent	action.start	aa63ea27550b96
756	2026-11-07T07:15:07	agent	action.done	04374e75bb6df8
757	2026-11-07T07:15:10	agent	decision	71202acd0e32d3
758	2026-11-07T07:15:10	agent	action.start	b2be7d3b58a1b8
759	2026-11-07T07:15:23	agent	action.done	b1ed121ae1341e
760	2026-11-07T07:15:27	agent	decision	9916b9b7a80eff
761	2026-11-07T07:15:27	agent	action.start	0063984a40638d
762	2026-11-07T07:15:33	agent	action.done	275cf330e2809f
763	2026-11-07T07:15:36	agent	decision	28126de22118ec
764	2026-11-07T07:15:36	agent	action.start	cdb68f89cbcc89
765	2026-11-07T07:18:11	agent	action.done	0a04c12ec1cf54
766	2026-11-07T07:18:16	agent	decision	2b555ffbd4a91f
767	2026-11-07T07:18:16	agent	action.start	1d3a37f2b1e3f7
768	2026-11-07T07:18:17	agent	action.done	26b0b68365afac
769	2026-11-07T07:18:17	agent	action.start	b14b6567f5aaeb
770	2026-11-07T07:18:17	agent	action.done	66e60eab0ee016
771	2026-11-07T07:18:17	agent	action.start	2ed2d78126e63b
772	2026-11-07T07:18:18	agent	action.done	f36ce4b92b437f
773	2026-11-07T07:18:18	agent	action.start	6d158d2c26d224
774	2026-11-07T07:18:18	agent	action.done	815fef52dd41ea
775	2026-11-07T07:18:18	agent	action.start	28349ec9781153
776	2026-11-07T07:18:18	agent	action.done	e7173c1e23332f
777	2026-11-07T07:18:18	agent	action.start	f531b3198fd709
778	2026-11-07T07:18:19	agent	action.done	e9227b84559eeb

#	Time (UTC)	Actor	Action	Hash
779	2026-11-07T07:18:19	agent	action.start	1691278080da64
780	2026-11-07T07:18:19	agent	action.done	af9f210cae52cf
781	2026-11-07T07:18:19	agent	action.start	f9793ccff166d1
782	2026-11-07T07:18:19	agent	action.done	0c8d95c78d7b89
783	2026-11-07T07:18:19	agent	action.start	64a373e188d0f1
784	2026-11-07T07:18:20	agent	action.done	194063b29501a2
785	2026-11-07T07:18:20	agent	action.start	dc88fdca7fbb58
786	2026-11-07T07:18:20	agent	action.done	95026739646788
787	2026-11-07T07:18:24	agent	approval.requested	ea6e8be24d1785
788	2026-11-07T07:18:24	agent	assessment.ready-for-review	8ab0daa69fbedb
789	2026-11-07T07:18:32	e2e-tester	approval.approved	fa4c5c90f73e85
790	2026-11-07T07:18:32	e2e-tester(approved)	action.start	87d102eae825c7
791	2026-11-07T07:21:32	e2e-tester(approved)	action.done	c01eb266c839a2
792	2026-11-07T07:21:32	agent	approval.outcome	03e14b42450343
793	2026-11-07T07:21:35	agent	assessment.ready-for-review	0503b37f677cb7
794	2026-11-07T07:21:44	analyst	approval.requested	9016bedb882f72
795	2026-11-07T07:21:46	e2e-tester	approval.rejected	9a9df20e348a10
796	2026-11-07T07:21:48	agent	assessment.ready-for-review	022f2b14f2a27e
797	2026-11-07T07:21:52	analyst	approval.requested	f084a180d626ac
798	2026-11-07T07:21:55	e2e-tester	approval.approved	5e5588fb80d031
799	2026-11-07T07:21:55	e2e-tester(approved)	action.start	68bc47b11564f5
800	2026-11-07T07:22:34	e2e-tester(approved)	action.done	906cdccd6029e7
801	2026-11-07T07:22:34	agent	approval.outcome	02a6efc4327327
802	2026-11-07T07:22:36	agent	assessment.ready-for-review	1cdb287da6ba27
803	2026-11-07T07:22:43	analyst	import	430051ae3359d9
804	2026-11-07T07:22:44	agent	assessment.ready-for-review	362d7f4052cc20
805	2026-11-07T07:22:46	analyst	import	44264c1ecb1b11
806	2026-11-07T07:22:47	agent	assessment.ready-for-review	1b7e4c300cde08
807	2026-11-07T07:22:49	analyst	import	fa35a047bc7ddc
808	2026-11-07T07:22:51	agent	assessment.ready-for-review	1587106e078da0
809	2026-11-07T07:22:55	scope-guard	import.dropped	cf01a7b46b4673
810	2026-11-07T07:22:55	analyst	import	10565f1638b74a
811	2026-11-07T07:22:56	agent	assessment.ready-for-review	8ad3ebcec9fba7
812	2026-11-07T07:23:07	analyst	retest	963dfd77e48ae9
813	2026-11-07T07:24:15	analyst	report.download	0977aca07377b8